ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Rockwell Automation PowerFlex 527 (520-series, integrated motion) AC Drive · Component type: **Embedded Device (EDR) - integrated-motion compact VFD** · Target SL = SL 3

Where to work	Almost everything is in **Studio 5000 Logix Designer** - the 527 is added as an **EtherNet/IP module / integrated-motion axis** owned by a Logix controller; there is **no local keypad**. Also: **Connected Components Workbench (CCW)** for standalone parameter access, **FactoryTalk Security** for engineering rights, the embedded **EtherNet/IP web page**, firmware via **ControlFLASH / CCW**.
Interfaces	Dual embedded **EtherNet/IP** only (no DSI/serial control on the 527); configured through the owning Logix controller. Parameters follow the 520-series letter+number scheme but are typically set via the AOP / axis configuration rather than a panel.
Notes	EDR - 520-series integrated-motion compact drive (PowerFlex 527). Confirm firmware rev and the owning controller. **Important:** like the 520-series generally, the 527 has a light native security stack (no CIP Security, no drive login). Because it is controller-owned, Logix/FactoryTalk Security and segmentation are the primary SL-3 controls - document them explicitly.
How to read	Read-only: review the Studio 5000 module/axis config, the CCW parameter set, and the embedded web page. Native how-to (exact location/param) + external-tool validation + pass, with honest Partial/Compensating where native controls are thin. Scans authorized; fuzz ISOLATED lab only.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.1	Human user identification & auth	The 527 has **no local login/keypad**; all human access is through Studio 5000 / CCW on the engineering workstation. Enforce authentication there: confirm **FactoryTalk Security** governs who may go online with the owning controller and edit the 527 module/axis, and that CCW/RSLinx access is controlled on the EWS. Record the drive-level absence as a residual. **Test:** confirm no external unauthenticated path (open web/CIP) can change the drive from outside the cell. **Ext. tools:** FactoryTalk Admin Console (users); Nmap/CCW (external write attempt - must fail at the zone).	Access authenticated via FactoryTalk/Logix/EWS; drive-level absence documented.	Partial/Compensating.
SR/CR 1.2	Software process / device identification	Confirm the 527 is uniquely identified: in Studio 5000 the module has a defined IP/host name and is associated to exactly one owning controller; in CCW read the Group C IP params. Each comm partner has a distinct EtherNet/IP identity. **Ext. tools:** Studio 5000 (module IP/owner); CCW (Group C); Wireshark.	Unique drive identity; single owning controller; partners identified.	
SR/CR 1.3	Account management	No drive accounts exist; manage FactoryTalk users/roles for the owning-controller project and OS accounts on the EWS - least privilege, no defaults, no shared logins. **Ext. tools:** FactoryTalk Admin Console; EWS local/AD accounts.	Surrounding accounts managed/least-privilege; drive has none by design.	Compensating.
SR/CR 1.4	Identifier management	Confirm a unique drive identity (EtherNet/IP address + module name in Studio 5000 + nameplate serial); no address/name reuse across drives; unique FactoryTalk user IDs. **Ext. tools:** Studio 5000 / CCW device info; network inventory.	Unique user and device identifiers; no reuse.	
SR/CR 1.5 / 1.7	Authenticator management & strength	Enforce strong authenticators where they exist - FactoryTalk password policy and EWS OS policy. If the embedded web server or any SMTP/email-on-fault feature is enabled, ensure no unauthenticated write; prefer disabling it (7.6). **Ext. tools:** FactoryTalk password policy; embedded web/SMTP check.	Strong managed authenticators at surrounding layers; unneeded services off.	Compensating.
SR/CR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 1.8 / 1.9	PKI certificates & key strength	**N/A at the drive.** The 527 does not support CIP Security / device certificates. Record N/A with justification; integrity/confidentiality is provided by segmentation and by TLS at the SCADA/EWS layer. **Ext. tools:** Confirm no CIP Security capability.	N/A at drive (no PKI support); compensating TLS/segmentation upstream.	N/A

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.10	Authenticator feedback	Confirm Studio 5000 / FactoryTalk logon and EWS login mask password entry (drive has no login prompt). **Ext. tools:** Visual verification.	Authenticators obscured at the interfaces that have them.	
SR/CR 1.11	Unsuccessful login attempts	Enforce lockout at the layers that authenticate (FactoryTalk lockout policy, EWS/AD lockout). The drive has no login to lock; note as residual. **Ext. tools:** FactoryTalk / AD lockout policy; SIEM failed-auth.	Lockout at surrounding layers; drive residual noted.	Compensating.
SR/CR 1.12	System use notification	No drive banner; enforce the approved use notice on the EWS (GPO) and HMI. **Ext. tools:** EWS GPO / HMI banner review.	Use notice at EWS/HMI (compensating).	Compensating.
SR/CR 1.13	Access via untrusted networks	Confirm the 527 EtherNet/IP is reachable only from the trusted cell zone behind the cell firewall / Stratix ACLs; remote engineering only via VPN; deny drive access from untrusted networks. Key control for a light-security drive. **Ext. tools:** Nmap (from untrusted side - expect no reach); firewall/ACL review.	Access from untrusted networks denied; remote via VPN.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.1	Authorization enforcement	The 527 is **owned by one Logix controller** - confirm the axis/module is associated to only the authorized controller and connection ownership is exclusive, so no other device can command it; FactoryTalk Security limits who may edit that controller's project. **Test:** attempt to establish a second owning connection - it must be refused (already-owned). **Ext. tools:** Studio 5000 (module ownership/connection); attempt 2nd owner (isolated) - refused.	Exclusive controller ownership; FactoryTalk rights least-privilege.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 2.3	Use control for portable/mobile devices	Control the engineering laptop and any USB used for firmware; removable-media policy on the EWS; only authorized projects loaded. **Ext. tools:** Physical inspection; EWS removable-media policy.	Portable/engineering media controlled.	
SR/CR 2.4 (+ EDR 2.4)	Mobile code	No general-purpose mobile code on the drive; confirm only drive firmware + parameters run and embedded web content is vendor read-only. **Ext. tools:** CCW / embedded web review.	Only trusted firmware/config runs; no untrusted mobile code.	EDR-specific.
SR/CR 2.5	Session lock	Confirm Studio 5000 / CCW and EWS sessions time out on inactivity and require re-auth (drive has no session concept). **Ext. tools:** Studio 5000 / EWS timeout config.	Engineering sessions lock/timeout; re-auth required.	Compensating.
SR/CR 2.6	Remote session termination	Confirm remote engineering (RDP/VPN to the EWS) can be terminated and idle sessions close; the owning CIP connection is exclusive and limited. **Ext. tools:** EWS/VPN session review; Studio 5000 connection review.	Remote sessions terminable on demand and on inactivity.	
SR/CR 2.7	Concurrent session control	Confirm the owning connection is exclusive and concurrent monitoring connections to the embedded adapter are bounded, preventing conflicting simultaneous control. **Ext. tools:** Studio 5000 / adapter connection review; Wireshark.	Ownership exclusive; concurrent connections bounded/monitored.	
SR/CR 2.8 / 2.12	Auditable events & non-repudiation	The drive keeps a fault log but no user-attributed audit. Capture configuration/firmware changes in **FactoryTalk AssetCentre** (Audit + DR) with the acting user, and forward EWS/FactoryTalk events to the SIEM; read the drive fault log via Studio 5000/CCW. **Ext. tools:** AssetCentre audit; Studio 5000/CCW fault log; SIEM.	Changes audited/attributable via AssetCentre/EWS; drive faults captured.	Compensating.
SR/CR 2.9	Audit storage capacity	Drive fault log is a small fixed depth; retention via AssetCentre / SIEM - confirm sizing and threshold alerting. **Ext. tools:** AssetCentre DB sizing; SIEM retention.	Events offloaded and retained; alert before capacity.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.10	Response to audit processing failures	Confirm the SIEM/AssetCentre alerts on forwarding/collection failure. **Ext. tools:** SIEM / AssetCentre health alerting.	Audit-failure alerting defined.	
SR/CR 2.11	Timestamps	The drive has no RTC; event time comes from the owning controller/AssetCentre - confirm those are NTP-synced. **Ext. tools:** NTP / controller time review.	Reliable, synchronized timestamps for drive events.	
EDR 2.13	Physical diagnostic & test interfaces	Control physical interfaces: keep the drive in a locked cabinet; secure the USB firmware port and Ethernet ports; there is no local keypad-start to disable (no HIM). Disable the embedded web server if unused. **Ext. tools:** Physical inspection; CCW/web (disable unused services).	Physical/diagnostic interfaces controlled; unused services disabled.	EDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 3.1 / 4.1	Communication integrity & confidentiality	The 527 EtherNet/IP is **unauthenticated cleartext CIP** (no CIP Security). Provide integrity/confidentiality by containing it in a segmented cell zone and terminating TLS at the SCADA/EWS layer; confirm no drive CIP traffic crosses a zone boundary in cleartext. **Ext. tools:** Wireshark (confirm cleartext CIP stays in-zone); firewall rule review.	Drive comms contained to the segmented zone; no cleartext CIP across boundaries.	Compensating.
EDR 3.2	Protection from malicious code (component)	Confirm only Rockwell firmware runs and there is no code-execution path. 520-series firmware lacks the 750-series signed-.dmk guarantee - verify provenance against PCDC and control the update path tightly (2.3/3.10). **Ext. tools:** CCW firmware rev; PCDC provenance check.	Only vendor firmware runs; provenance verified; no code path.	EDR-specific/Partial.
SR/CR 3.3	Security functionality verification	After any change re-verify: controller ownership, connection-loss action, embedded web-server state, and IP config, against the hardening baseline; compare the Studio 5000 module config / CCW project against the archived version. **Ext. tools:** Studio 5000 / CCW compare vs baseline; Nmap (services off).	Security-relevant settings match baseline after change.	
SR/CR 3.4	Software & information integrity	Archive the Studio 5000 project + 527 parameters in AssetCentre and enable change detection so unauthorized parameter/firmware change is detected. Compare online-vs-offline. **Ext. tools:** AssetCentre change detection; online-vs-offline compare.	Config integrity monitored; unauthorized change detected.	Compensating.
SR/CR 3.5	Input validation	Confirm the drive tolerates malformed EtherNet/IP/CIP frames without faulting or unsafe motion. **ISOLATED only:** fuzz the adapter on a bench drive and watch the fault log / connection status. **Ext. tools:** ENIP/CIP fuzzer (ISOLATED); Wireshark.	No crash or unsafe motion on malformed input.	Do NOT fuzz production.
SR/CR 3.6	Deterministic output	Verify the connection-loss / fault reaction so the motor reaches a defined safe state: in Studio 5000 set the module/axis **connection-loss action** (and the drive comm-fault action) to Fault/Stop as designed - not run-through - and where a hardwired safety/enable circuit is fitted, function-test it. **Ext. tools:** Studio 5000 (connection-loss/axis fault action); hardwired enable test (lab).	Drive faults/stops to a defined safe state on connection loss.	
SR/CR 3.7	Error handling	Confirm graceful fault handling: review the fault log and disable auto-restart unless justified so errors do not cause unsafe restart. **Ext. tools:** Studio 5000 / CCW (fault log; auto-restart config).	Graceful fault handling; no unsafe restart.	
SR/CR 3.8	Session integrity	**N/A at drive (no secured session).** Legacy CIP sessions are unauthenticated; integrity is provided by exclusive ownership + containment. Record N/A + compensating segmentation. **Ext. tools:** Wireshark (confirm in-zone containment).	N/A at drive; compensating ownership/segmentation recorded.	N/A
SR/CR 3.9	Protection of audit information	Protect the AssetCentre audit DB and SIEM store; restrict who can read/clear the drive fault log. **Ext. tools:** AssetCentre / SIEM access review.	Audit records protected from unauthorized read/modify/delete.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
EDR 3.10	Support for updates	Update firmware via ControlFLASH / CCW with firmware from PCDC; verify revision/provenance; plan the update in a maintenance window with rollback to the prior known-good file. (No on-drive signature check like 750-series.) **Ext. tools:** ControlFLASH/CCW; PCDC checksum/provenance.	Controlled updates from verified source, with rollback.	EDR-specific/Partial.
EDR 3.11	Physical tamper resistance/detection	Keep the drive in a locked, sealed cabinet; control the USB/Ethernet ports; AssetCentre change records and the drive fault log provide change evidence. **Ext. tools:** Physical inspection; AssetCentre / fault-log review.	Cabinet locked/sealed; interfaces controlled; changes logged.	EDR-specific.
EDR 3.12	Provisioning product-supplier roots of trust	**N/A at drive.** 520-series provides no signed-boot supplier root of trust. Record N/A; compensate via firmware update-provenance discipline (3.10), physical control, and segmentation. **Ext. tools:** Confirm no secure-boot / signed-firmware root capability.	N/A at drive (no supplier RoT); compensating controls recorded.	N/A
EDR 3.13	Provisioning asset-owner roots of trust	**N/A at drive.** 527 provides no CIP Security / asset-owner certificate provisioning. Record N/A; asset-owner trust is enforced at the controller/SCADA/EWS layer and by segmentation. **Ext. tools:** Confirm no CIP-Security / certificate-provisioning capability.	N/A at drive (no asset-owner RoT); compensating controls recorded.	N/A
EDR 3.14	Integrity of the boot process	**N/A at drive (no verified/secure boot).** Record N/A; mitigate via controlled firmware provenance (3.10), physical control, and monitoring. **Ext. tools:** Confirm no secure-boot capability; CCW firmware rev.	N/A at drive; compensating provenance/physical controls recorded.	N/A

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 4.2	Information persistence	On decommission/repurpose, in CCW/Studio 5000 reset the drive to factory defaults and clear config so it is not recoverable. **Ext. tools:** CCW/Studio 5000 (reset to defaults).	Sensitive configuration purged on decommission or reuse.	
SR/CR 4.3	Use of cryptography	**N/A at drive.** No native crypto on the 527; disable the embedded web server / any SMTP feature and rely on TLS at the SCADA/EWS layer and segmentation. **Ext. tools:** Confirm no drive crypto; disable web/SMTP (7.6).	N/A at drive; compensating TLS/segmentation upstream.	N/A

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 5.1 / 5.2	Network segmentation & zone boundary	Confirm the drive sits in a controlled cell/zone behind a firewall / Stratix ACLs; only required EtherNet/IP flows cross the boundary; no flat convergence with IT. Primary control for this light-security drive. **Ext. tools:** Nmap by zone; firewall/ACL rule review.	Drive in a segmented zone; only required flows cross the boundary.	
SR/CR 5.3	General-purpose person-to-person comms restrictions	Largely **N/A**, but if the embedded adapter's **fault email/SMTP notification** is enabled, disable it or restrict SMTP so the drive originates no general-purpose messaging. **Ext. tools:** CCW / embedded web (SMTP/email config) - confirm disabled.	N/A / any email-notification feature disabled.	N/A
SR/CR 5.4	Application partitioning	**N/A.** Single-purpose drive; no separable applications to partition. **Ext. tools:** Confirm single-function device.	N/A - justification recorded.	N/A

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 6.1 / 6.2	Audit log accessibility & continuous monitoring	Confirm drive faults (Studio 5000/CCW fault log) and AssetCentre change records are readable/exportable and forwarded to the SIEM; the cell is passively monitored (OT IDS on a mirror port). **Ext. tools:** AssetCentre export; passive OT IDS (mirror port).	Events accessible/exportable and monitored in near-real-time.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.1	Denial-of-service protection	Confirm DoS resilience: the adapter CIP connection limit plus cell-firewall rate-limiting prevent a flood from denying control; monitor the owning connection and comms status while testing. **Ext. tools:** Adapter connection review; traffic generator (ISOLATED).	Resources bounded; drive control continues under load.	
SR/CR 7.2	Resource management	Confirm the adapter bounds resource use (fixed CIP connection limit) so a single service cannot starve control. **Ext. tools:** Adapter connection/limits review.	Resources bounded; no exhaustion-based loss of control.	
SR/CR 7.3 / 7.4	Backup & recovery	Confirm the Studio 5000 project / 527 parameters are backed up (AssetCentre DR, versioned, offline) and a restore is tested for a known-good rebuild. **Ext. tools:** AssetCentre DR review; restore test (lab).	Backups current and recovery validated.	
SR/CR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6 / 7.7	Network & security settings + least functionality	Harden per baseline: disable the embedded **web server** and any **email/SMTP** feature if unused, set the connection-loss action, confirm exclusive controller ownership, and disable unused services/ports. **Ext. tools:** Studio 5000/CCW/web (disable web/SMTP); Nmap (exposed services).	Least functionality; unused services disabled per baseline.	
SR/CR 7.8	Component inventory	Confirm the drive (catalog, firmware rev, adapter) is inventoried so vulnerabilities track against Rockwell Automation security advisories. **Ext. tools:** Studio 5000/CCW/AssetCentre inventory; ReadOnlyEnum.	Accurate component/firmware inventory maintained.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
Studio 5000 Logix Designer	Owner/axis config & native review (all FRs)	Read the 527 module/axis: owning controller, IP/name, connection-loss action, fault log, firmware rev; compare to baseline.	Read/authorized project copy.
CCW	Standalone parameter access (1.2, 3.x, 4.2, 7.6)	Read Group C IP, comm-fault actions, and firmware rev when not viewing through Logix.	Read/authorized project copy.
FactoryTalk Security / Admin Console	Identity & authorization (FR1, 2.1)	Read FactoryTalk users/roles for the owning-controller project; least-privilege check.	Read-only.
FactoryTalk AssetCentre	Audit, change detection & DR (2.8, 3.4, 6.x, 7.3)	Audit config/firmware changes and provide versioned backup/restore.	Non-intrusive.
ControlFLASH / PCDC	Firmware update & provenance (3.2, 3.10)	Update from verified PCDC files; confirm revision/provenance.	Maintenance window.
Nmap / ReadOnlyEnum / Wireshark	Exposed-service, zone & comms review (1.13, 3.1, 5.x, 7.6)	Enumerate EtherNet/IP + embedded web per zone; confirm cleartext CIP stays in-zone.	Read-only/passive; authorized.
ENIP/CIP fuzzer / traffic generator	Input validation & DoS resilience (3.5, 7.1)	Malformed-frame / high-rate EtherNet/IP testing on a bench drive while watching fault log / connection health.	ISOLATED/non-production; written authorization.

Controlled - Project Use · Independent Assurance Authority · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.